

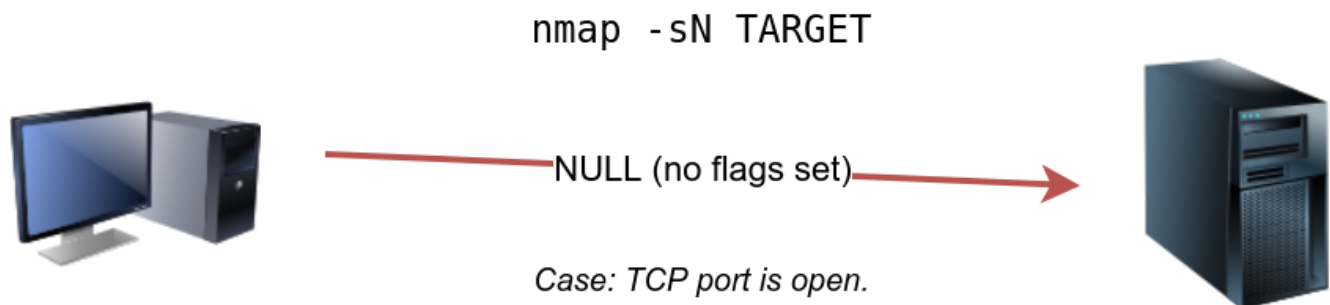
Nmap Advanced Port Scans

TCP Null Scan, FIN Scan, Xmas Scan

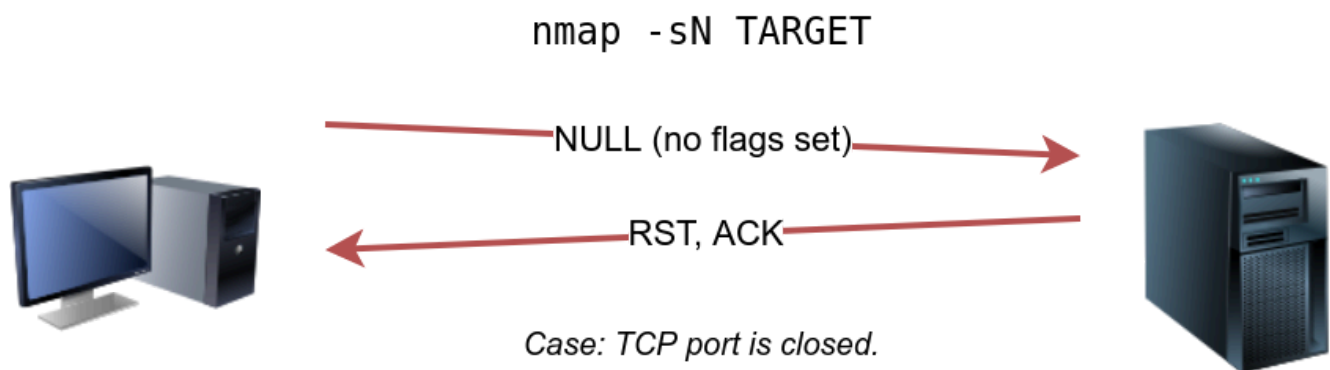
Null Scan

can choose this scan using the `-sN` option

a lack of reply in a null scan indicates that either the port is open or a firewall is blocking the packet.



the target server to respond with an RST packet if the port is closed
can use the lack of RST response to figure out the ports that are not closed: open or filtered



Example

```
pentester@TryHackMe$ sudo nmap -sN 10.129.133.92

Starting Nmap 7.60 ( https://nmap.org ) at 2021-08-30 10:30 BST
Nmap scan report for 10.129.133.92
Host is up (0.00066s latency).
Not shown: 994 closed ports
PORT      STATE      SERVICE
22/tcp    open|filtered ssh
25/tcp    open|filtered smtp
80/tcp    open|filtered http
110/tcp   open|filtered pop3
111/tcp   open|filtered rpcbind
143/tcp   open|filtered imap
MAC Address: 02:45:BF:8A:2D:6B (Unknown)

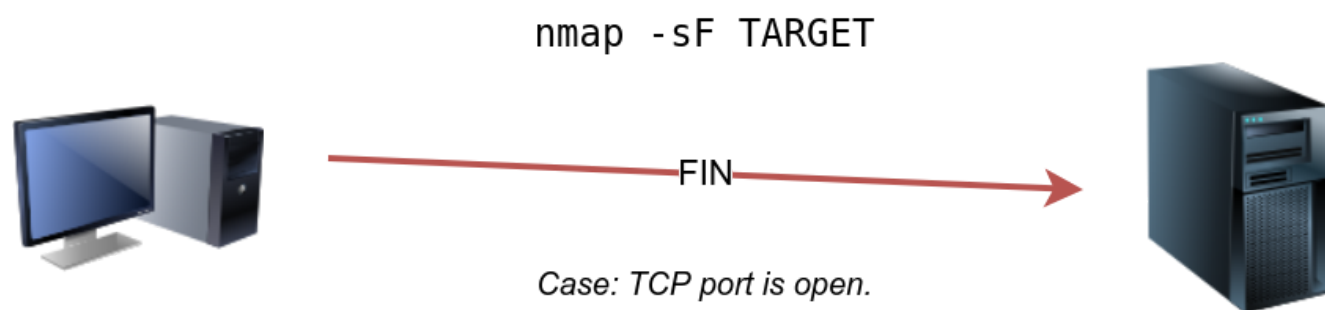
Nmap done: 1 IP address (1 host up) scanned in 96.50 seconds
```

Unless you are running Nmap as root, you need to use `sudo` as in the example above using the `-sN` option

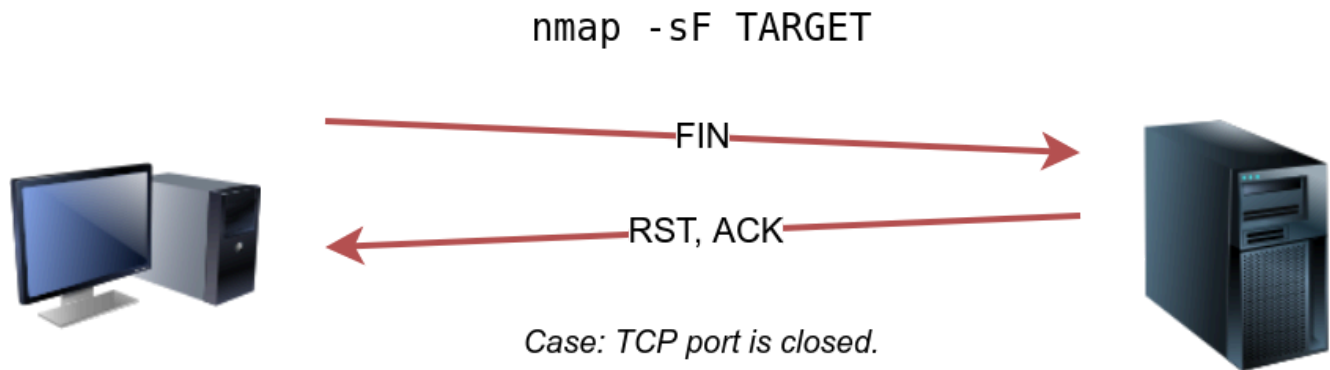
FIN Scan

FIN scan sends a TCP packet with the FIN flag set

can choose this scan type using the `-sF` option



no response will be sent if the TCP port is open.
the target system should respond with an RST if the port is closed



Example:

```
pentester@TryHackMe$ sudo nmap -sF 10.129.133.92

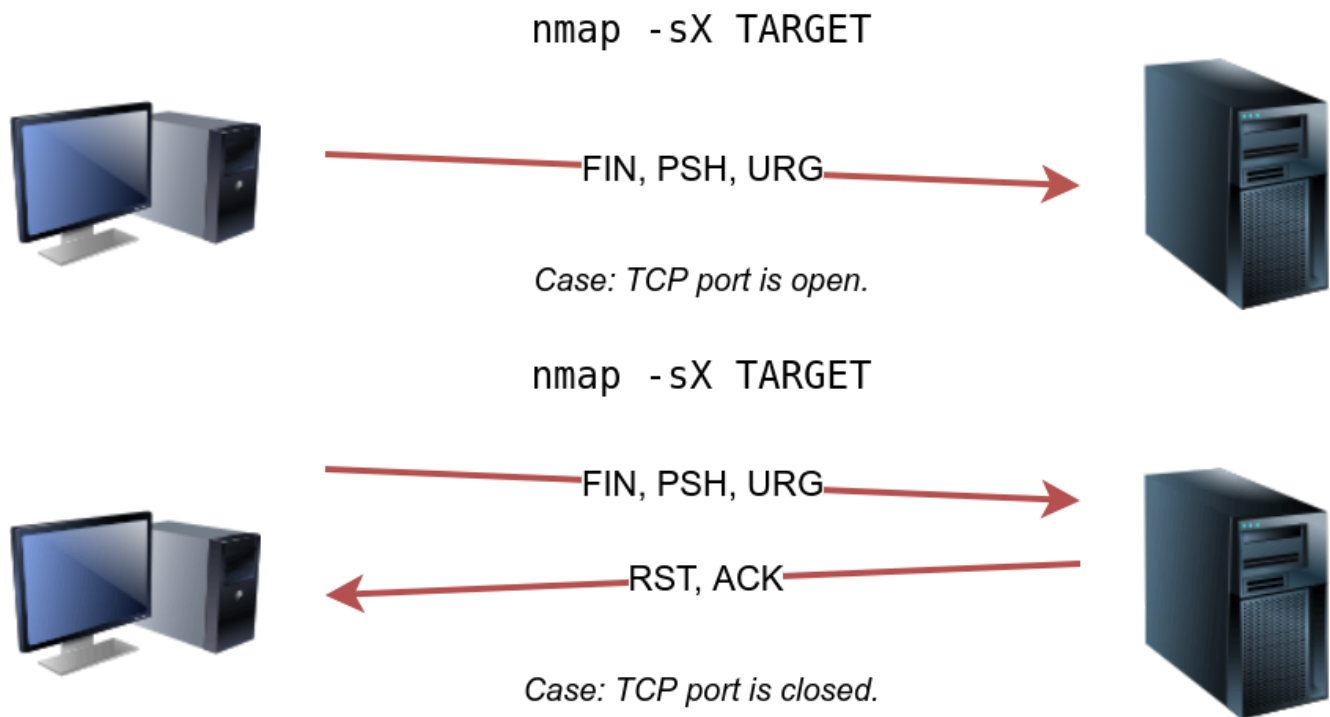
Starting Nmap 7.60 ( https://nmap.org ) at 2021-08-30 10:32 BST
Nmap scan report for 10.129.133.92
Host is up (0.0018s latency).
Not shown: 994 closed ports
PORT      STATE      SERVICE
22/tcp    open|filtered ssh
25/tcp    open|filtered smtp
80/tcp    open|filtered http
110/tcp   open|filtered pop3
111/tcp   open|filtered rpcbind
143/tcp   open|filtered imap
MAC Address: 02:45:BF:8A:2D:6B (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 96.52 seconds
```

Xmas Scan

An Xmas scan sets the FIN, PSH, and URG flags simultaneously. You can select Xmas scan with the option `-sX`

if an RST packet is received, it means that the port is closed. Otherwise, it will be reported as open|filtered.



Example:

```
pentester@TryHackMe$ sudo nmap -sX 10.129.133.92

Starting Nmap 7.60 ( https://nmap.org ) at 2021-08-30 10:34 BST
Nmap scan report for 10.129.133.92
Host is up (0.00087s latency).
Not shown: 994 closed ports
PORT      STATE      SERVICE
22/tcp    open|filtered ssh
25/tcp    open|filtered smtp
80/tcp    open|filtered http
110/tcp   open|filtered pop3
111/tcp   open|filtered rpcbind
143/tcp   open|filtered imap
MAC Address: 02:45:BF:8A:2D:6B (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 84.85 seconds
```

One scenario where these three scan types can be efficient is when scanning a target behind a stateless (non-stateful) firewall. A stateless firewall will check if the incoming packet has the SYN flag set to detect a connection attempt

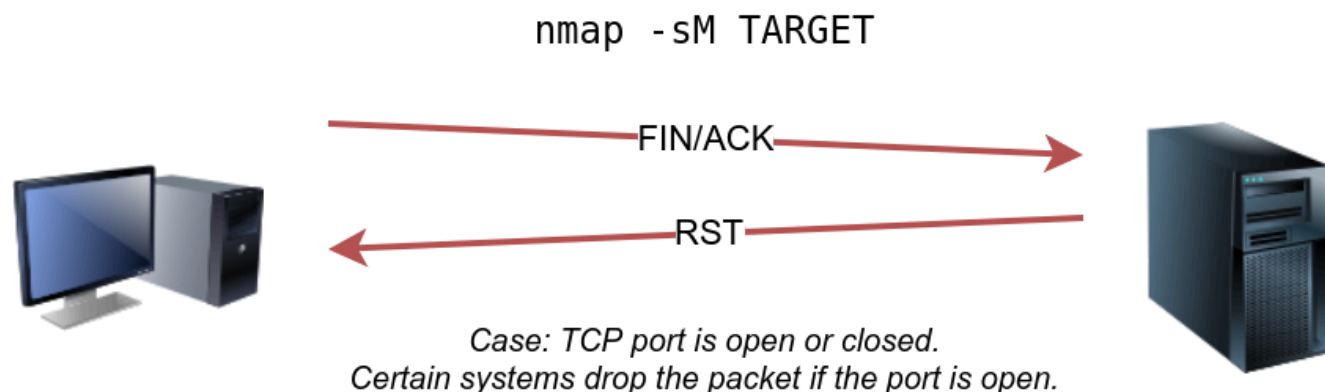
Using a flag combination that does not match the SYN packet makes it possible to deceive the firewall and reach the system behind it. However, a stateful firewall will practically block all such crafted packets and render this kind of scan useless.

TCP Maimon Scan

FIN and ACK bits are set. The target should send an RST packet as a response.

certain BSD-derived systems drop the packet if it is an open port exposing the open ports.
This scan won't work on most targets encountered in modern networks

To select this scan type, use the `-sM` option.



Example:

because open ports and closed ports are behaving the same way, the Maimon scan could not discover any open ports on the target system.

```
pentester@TryHackMe$ sudo nmap -sM 10.10.252.27
```

```
Starting Nmap 7.60 ( https://nmap.org ) at 2021-08-30 10:36 BST
```

```
Nmap scan report for ip-10-10-252-27.eu-west-1.compute.internal (10.10.252.27)
```

```
Host is up (0.00095s latency).
```

```
All 1000 scanned ports on ip-10-10-252-27.eu-west-1.compute.internal (10.10.252.27
```

```
MAC Address: 02:45:BF:8A:2D:6B (Unknown)
```

```
Nmap done: 1 IP address (1 host up) scanned in 1.61 seconds
```

TCP ACK, Window, Custom Scan

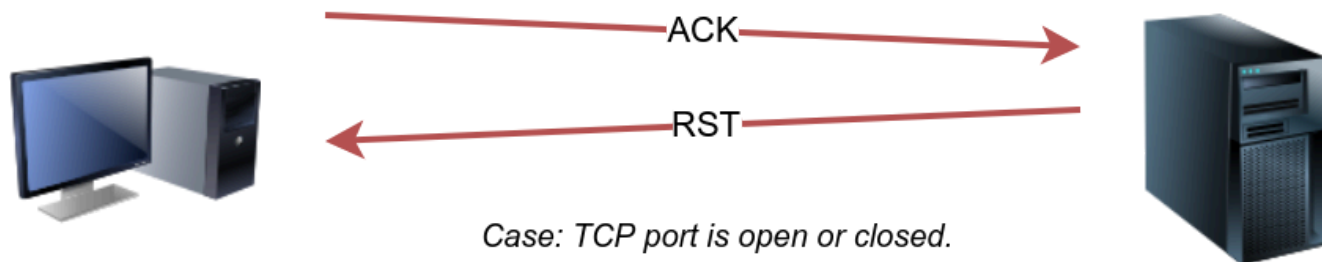
TCP ACK Scan

an ACK scan will send a TCP packet with the ACK flag set.

`-sA` option to choose this scan

the target would respond to the ACK with RST regardless of the state of the port

`nmap -sA TARGET`



In the following example, we scanned the target VM before installing a firewall on it. As expected, we couldn't learn which ports were open.

```
Pentester Terminal

pentester@TryHackMe$ sudo nmap -sA 10.129.146.146

Starting Nmap 7.60 ( https://nmap.org ) at 2021-08-30 10:37 BST
Nmap scan report for 10.129.146.146
Host is up (0.0013s latency).
All 1000 scanned ports on 10.129.146.146 are unfiltered
MAC Address: 02:45:BF:8A:2D:6B (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 1.68 seconds
```

This kind of scan would be helpful if there is a firewall in front of the target

based on which ACK packets resulted in responses, you will learn which ports were not blocked by the firewall

suitable to discover firewall rule sets and configuration.

example with firewall set:

```
pentester@TryHackMe$ sudo nmap -sA 10.129.146.146

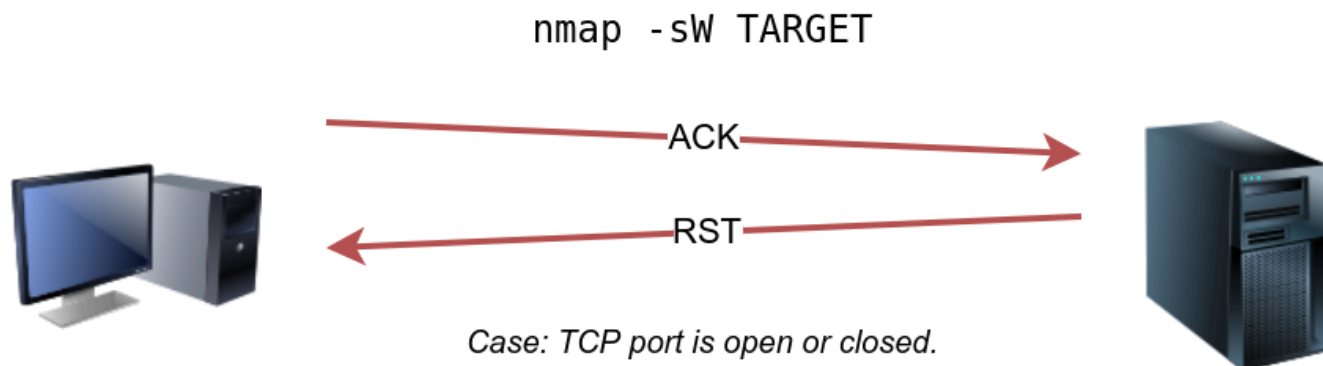
Starting Nmap 7.60 ( https://nmap.org ) at 2021-09-07 11:34 BST
Nmap scan report for 10.129.146.146
Host is up (0.00046s latency).
Not shown: 997 filtered ports
PORT      STATE      SERVICE
22/tcp    unfiltered ssh
25/tcp    unfiltered smtp
80/tcp    unfiltered http
MAC Address: 02:78:C0:D0:4E:E9 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 15.45 seconds
```

Window Scan

The TCP window scan is almost the same as the ACK scan; however, it examines the TCP Window field of the RST packets returned

select this scan type with the option `-sW`



launching a TCP window scan against a Linux system with no firewall will not provide much information

```
pentester@TryHackMe$ sudo nmap -sW 10.129.146.146

Starting Nmap 7.60 ( https://nmap.org ) at 2021-08-30 10:38 BST
Nmap scan report for 10.129.146.146
Host is up (0.0011s latency).
All 1000 scanned ports on ip-10-10-252-27.eu-west-1.compute.internal (10.10.252.27)
MAC Address: 02:45:BF:8A:2D:6B (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 1.60 seconds
```

if we repeat our TCP window scan against a server behind a firewall, we expect to get more satisfying results

```
pentester@TryHackMe$ sudo nmap -sW 10.129.146.146

Starting Nmap 7.60 ( https://nmap.org ) at 2021-09-07 11:39 BST
Nmap scan report for 10.129.146.146
Host is up (0.00040s latency).
Not shown: 997 filtered ports
PORT      STATE SERVICE
22/tcp    closed ssh
25/tcp    closed smtp
80/tcp    closed http
MAC Address: 02:78:C0:D0:4E:E9 (Unknown)

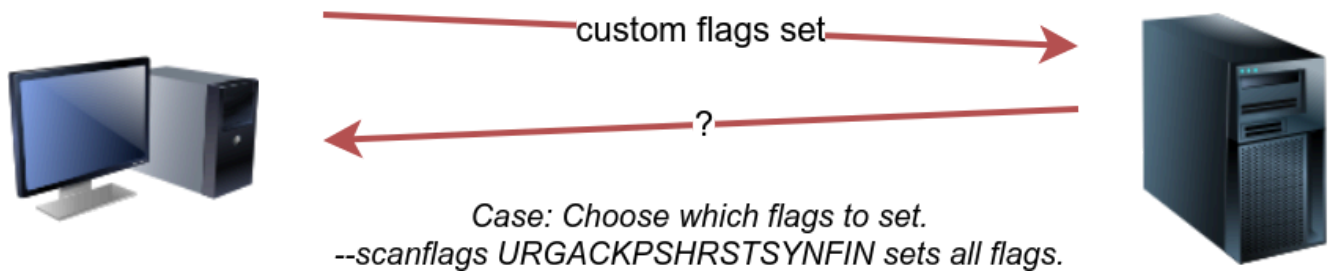
Nmap done: 1 IP address (1 host up) scanned in 14.84 seconds
```

the TCP window scan pointed that three ports are detected as closed. (This is in contrast with the ACK scan that labelled the same three ports as unfiltered.) Although we know that these three ports are not closed, we realize they responded differently, indicating that the firewall does not block them.

Custom Scan

if you want to experiment with a new TCP flag combination beyond the built-in TCP scan types, you can do so using `--scanflags` . For instance, if you want to set SYN, RST, and FIN simultaneously, you can do so using `--scanflags RSTSYNFIN`


```
nmap --scanflags CUSTOM_FLAGS TARGET
```



ACK scan and the window scan were very efficient at helping us map out the firewall rules

just because a firewall is not blocking a specific port, it does not necessarily mean that a service is listening on that port

there is a possibility that the firewall rules need to be updated to reflect recent service changes. Hence, ACK and window scans are exposing the firewall rules, not the services.

Spoofing and Decoys

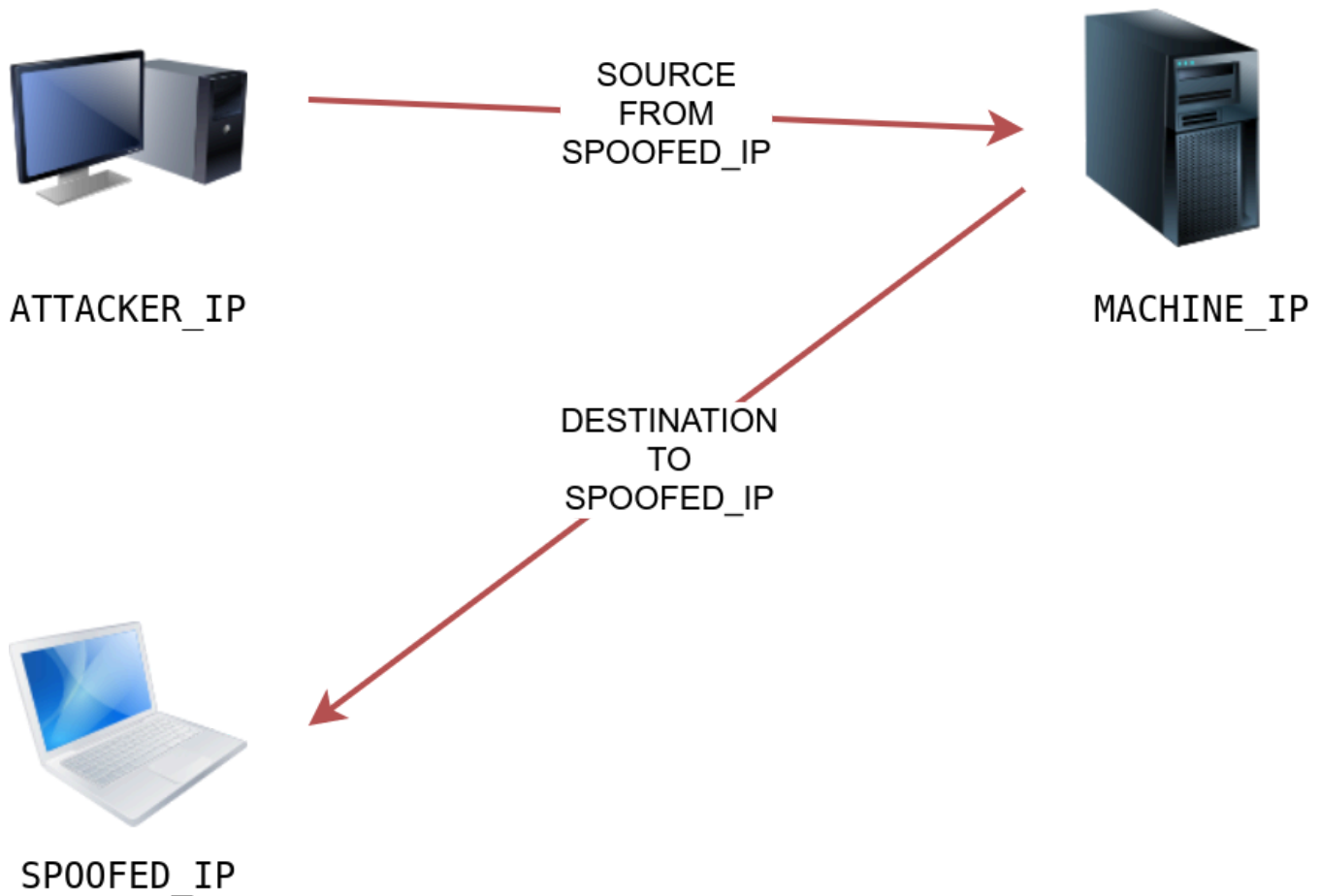
In some network setups, you will be able to scan a target system using a spoofed IP address and even a spoofed MAC address

Such a scan is only beneficial in a situation where you can guarantee to capture the response

```
nmap -S SPOOFED_IP MACHINE_IP
```

Nmap will craft all the packets using the provided source IP address `SPOOFED_IP`. The target machine will respond to the incoming packets sending the replies to the destination IP address `SPOOFED_IP`. For this scan to work and give accurate results, the attacker needs to monitor the network traffic to analyse the replies.

`nmap -S SPOOFED_IP MACHINE_IP`



Using SPOOFED_IP as the source IP address for the scan.

In brief, scanning with a spoofed IP address is three steps:

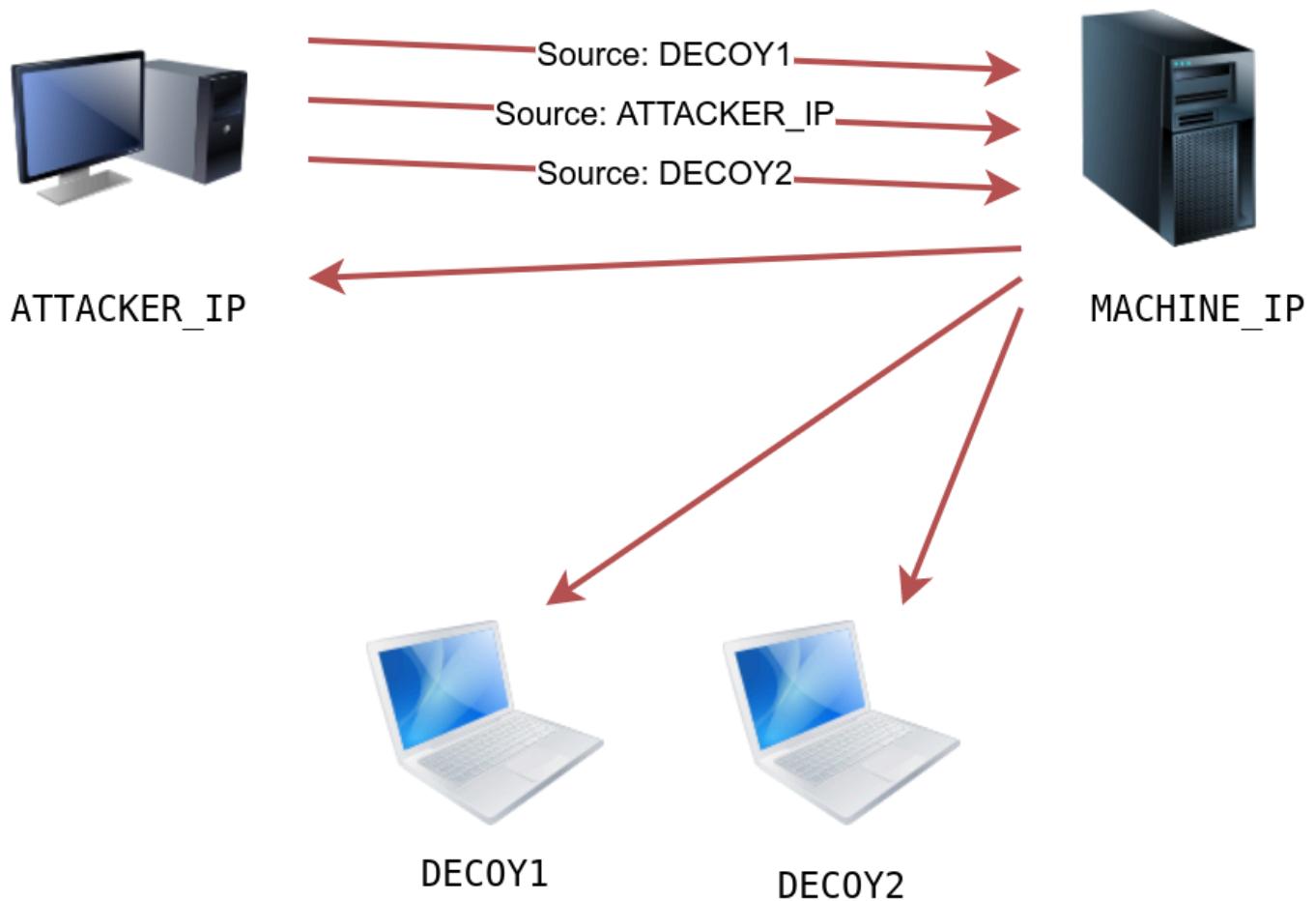
1. Attacker sends a packet with a spoofed source IP address to the target machine.
2. Target machine replies to the spoofed IP address as the destination.
3. Attacker captures the replies to figure out open ports.

you expect to specify the network interface using `-e` and to explicitly disable ping scan `-Pn`

instead of `nmap -S SPOOFED_IP MACHINE_IP`, you will need to issue `nmap -e NET_INTERFACE -Pn -S SPOOFED_IP MACHINE_IP` to tell Nmap explicitly which network interface to use and not to expect to receive a ping reply

When you are on the same subnet as the target machine, you would be able to spoof your MAC address as well. You can specify the source MAC address using `--spoof-mac SPOOFED_MAC`

```
nmap -D DECOY1,ME,DECOY2 MACHINE_IP
```



*Using DECOY1, ATTACKER_IP, DECOY2
as the source IP addresses for the scan.*

Launch a decoy scan by specifying a specific or random IP address after `-D`. For example, `nmap -D 10.10.0.1,10.10.0.2,ME MACHINE_IP`

Another example command would be `nmap -D 10.10.0.1,10.10.0.2,RND,RND,ME MACHINE_IP`

Fragmented Packets

Firewall

software or hardware that permits packets to pass through or blocks them. It functions based on firewall rules, summarized as blocking all traffic with exceptions or allowing all traffic with exceptions

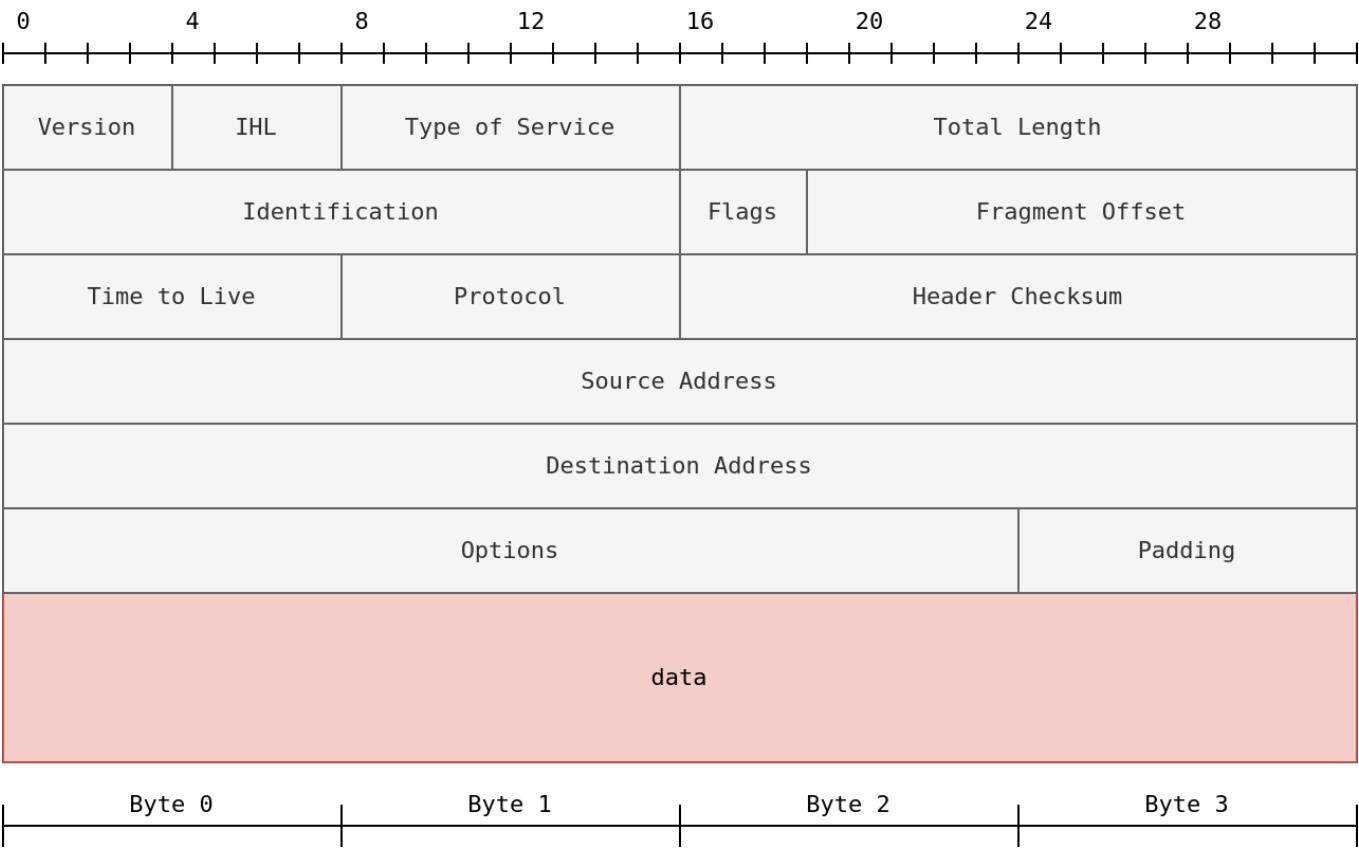
IDS

An intrusion detection system (IDS) inspects network packets for select behavioural patterns or specific content signatures. It raises an alert whenever a malicious rule is met. In addition to the IP header and transport layer header, an IDS would inspect the data contents in the transport layer and check if it matches any malicious patterns

Fragmented Packets

Nmap provides the option `-f` to fragment packets. Once chosen, the IP data will be divided into 8 bytes or less. Adding another `-f` (`-f -f` or `-ff`) will split the data into 16 byte-fragments instead of 8. You can change the default value by using the `--mtu` ; however, you should always choose a multiple of 8.

IP Header (RFC 791)



notice the source address taking 32 bits (4 bytes) on the fourth row, while the destination address is taking another 4 bytes on the fifth row. The data that we will fragment across multiple packets is highlighted in red

if you prefer to increase the size of your packets to make them look innocuous, you can use the option `--data-length NUM` , where num specifies the number of bytes you want to append to your packets.

Idle/Zombie Scan

requires an idle system connected to the network that you can communicate with.

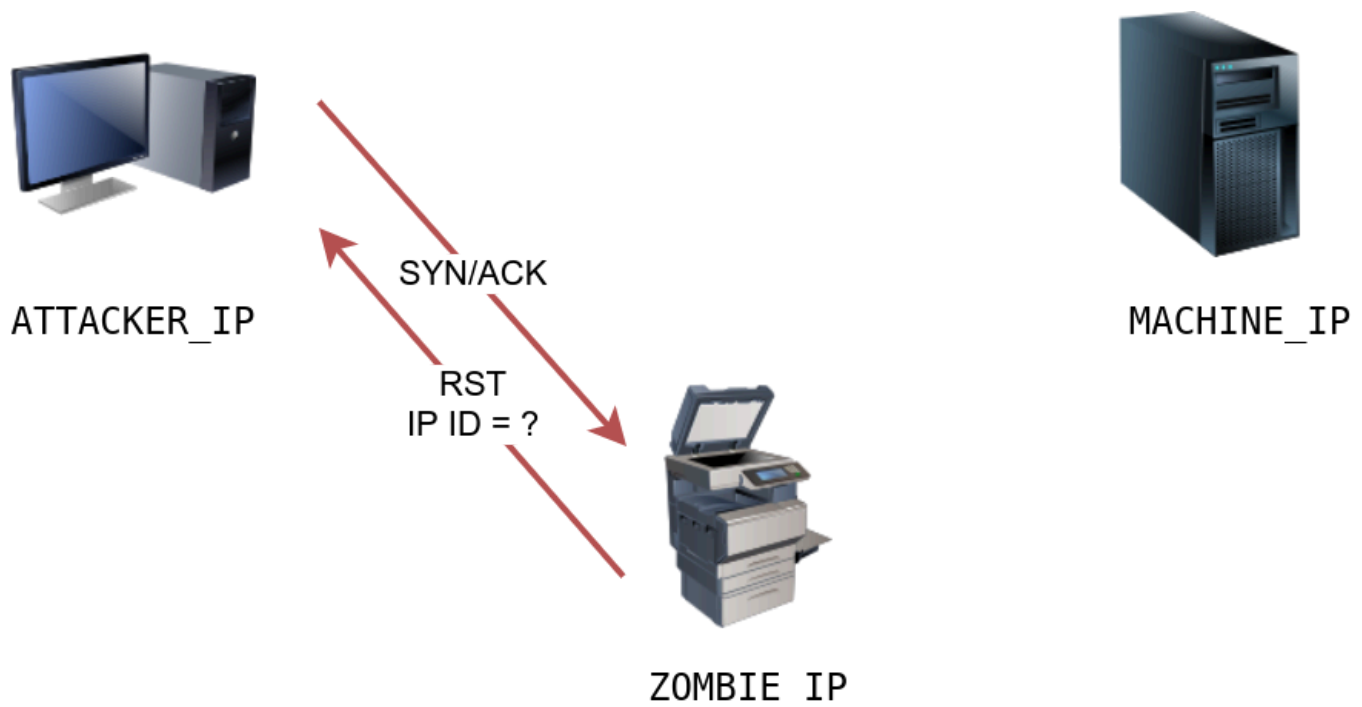
Practically, Nmap will make each probe appear as if coming from the idle (zombie) host, then it will check for indicators whether the idle (zombie) host received any response to the spoofed probe

This is accomplished by checking the IP identification (IP ID) value in the IP header. You can run an idle scan using `nmap -sI ZOMBIE_IP MACHINE_IP`, where `ZOMBIE_IP` is the IP address of the idle host (zombie).

The idle (zombie) scan requires the following three steps to discover whether a port is open:

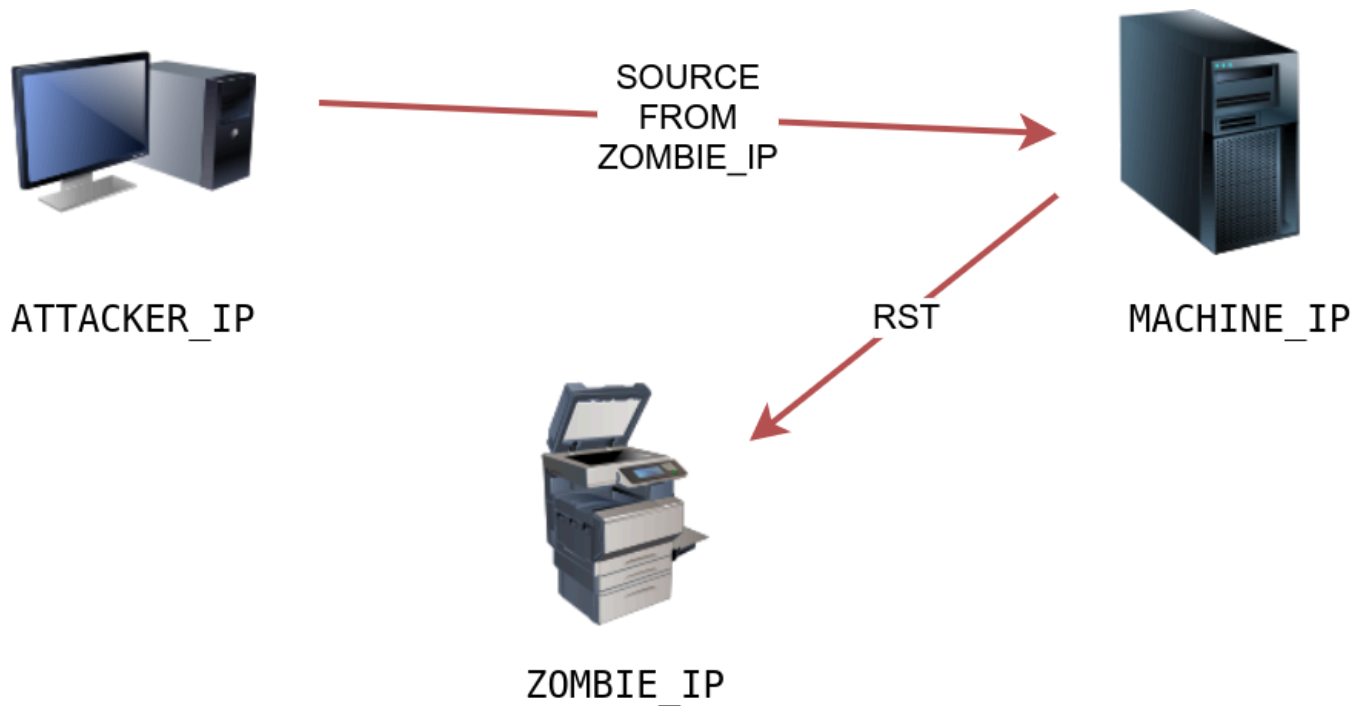
1. Trigger the idle host to respond so that you can record the current IP ID on the idle host.
2. Send a SYN packet to a TCP port on the target. The packet should be spoofed to appear as if it was coming from the idle host (zombie) IP address.
3. Trigger the idle machine again to respond so that you can compare the new IP ID with the one received earlier.

attacker system probing an idle machine, a multi-function printer. By sending a SYN/ACK, it responds with an RST packet containing its newly incremented IP ID.

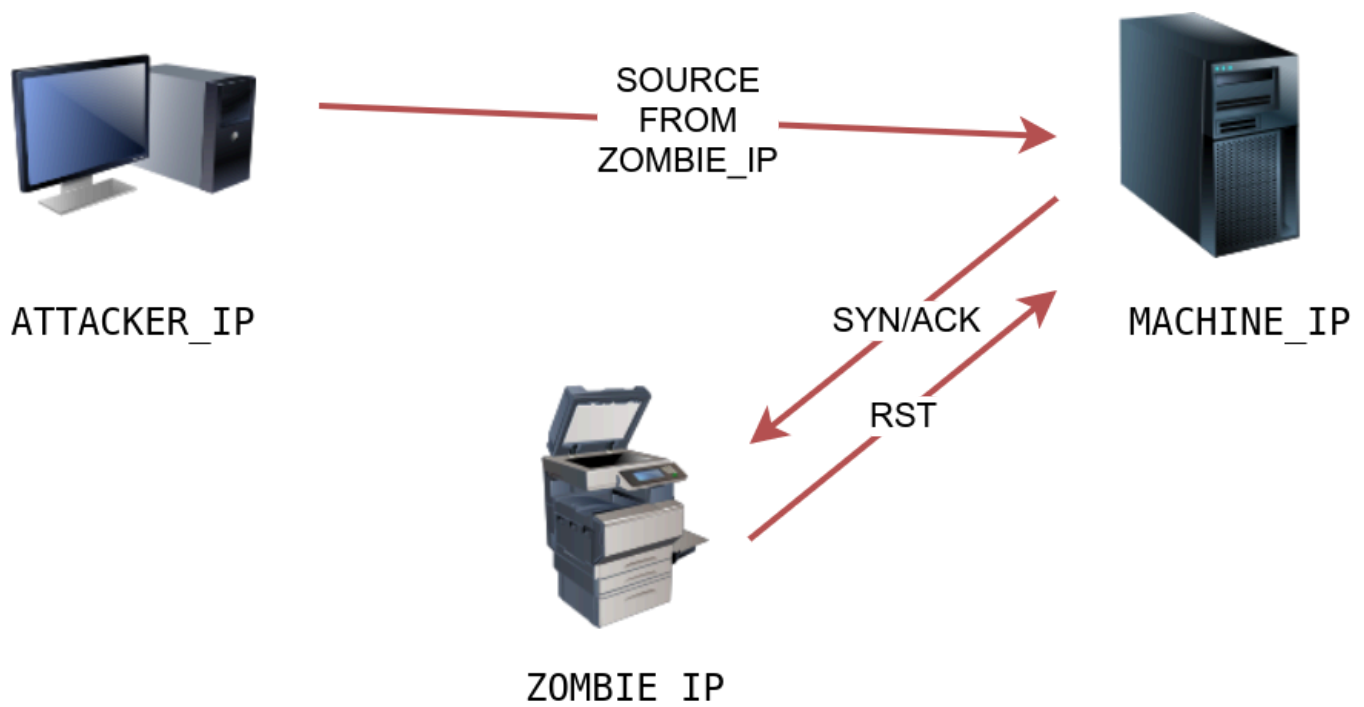


Attacker system communicates with an idle system to find its current IP ID

attacker will send a SYN packet to the TCP port they want to check on the target machine in the next step. However, this packet will use the idle host (zombie) IP address as the source.



Attacker system sends to target machine a SYN packet spoofed as sent by the idle system.
Case: Port is closed



Attacker system sends to target machine a SYN packet spoofed as sent by the idle system.
Case: Port is open

Getting more details

You might consider adding `--reason` if you want Nmap to provide more details regarding its reasoning and conclusions. Consider the two scans below to the system; however, the latter

adds `--reason`.

```
Pentester Terminal

pentester@TryHackMe$ sudo nmap -sS 10.10.252.27

Starting Nmap 7.60 ( https://nmap.org ) at 2021-08-30 10:39 BST
Nmap scan report for ip-10-10-252-27.eu-west-1.compute.internal (10.10.252.27)
Host is up (0.0020s latency).
Not shown: 994 closed ports
PORT      STATE SERVICE
22/tcp    open  ssh
25/tcp    open  smtp
80/tcp    open  http
110/tcp   open  pop3
111/tcp   open  rpcbind
143/tcp   open  imap
MAC Address: 02:45:BF:8A:2D:6B (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 1.60 seconds
```

```
Pentester Terminal

pentester@TryHackMe$ sudo nmap -sS --reason 10.10.252.27

Starting Nmap 7.60 ( https://nmap.org ) at 2021-08-30 10:40 BST
Nmap scan report for ip-10-10-252-27.eu-west-1.compute.internal (10.10.252.27)
Host is up, received arp-response (0.0020s latency).
Not shown: 994 closed ports
Reason: 994 resets
PORT      STATE SERVICE REASON
22/tcp    open  ssh     syn-ack ttl 64
25/tcp    open  smtp    syn-ack ttl 64
80/tcp    open  http    syn-ack ttl 64
110/tcp   open  pop3     syn-ack ttl 64
111/tcp   open  rpcbind syn-ack ttl 64
143/tcp   open  imap     syn-ack ttl 64
MAC Address: 02:45:BF:8A:2D:6B (Unknown)
```

`--reason` flag gives us the explicit reason why Nmap concluded that the system is up or a particular port is open

For more detailed output, you can consider using `-v` for verbose output or `-vv` for even more verbosity.

```
Pentester Terminal

pentester@TryHackMe$ sudo nmap -sS -vv 10.10.252.27

Starting Nmap 7.60 ( https://nmap.org ) at 2021-08-30 10:41 BST
Initiating ARP Ping Scan at 10:41
Scanning 10.10.252.27 [1 port]
Completed ARP Ping Scan at 10:41, 0.22s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 10:41
Completed Parallel DNS resolution of 1 host. at 10:41, 0.00s elapsed
Initiating SYN Stealth Scan at 10:41
Scanning ip-10-10-252-27.eu-west-1.compute.internal (10.10.252.27) [1000 ports]
Discovered open port 22/tcp on 10.10.252.27
Discovered open port 25/tcp on 10.10.252.27
Discovered open port 80/tcp on 10.10.252.27
Discovered open port 110/tcp on 10.10.252.27
Discovered open port 111/tcp on 10.10.252.27
Discovered open port 143/tcp on 10.10.252.27
Completed SYN Stealth Scan at 10:41, 1.25s elapsed (1000 total ports)
Nmap scan report for ip-10-10-252-27.eu-west-1.compute.internal (10.10.252.27)
Host is up, received arp-response (0.0019s latency).
Scanned at 2021-08-30 10:41:02 BST for 1s
Not shown: 994 closed ports
Reason: 994 resets
PORT      STATE SERVICE REASON
22/tcp    open  ssh     syn-ack ttl 64
25/tcp    open  smtp    syn-ack ttl 64
80/tcp    open  http    syn-ack ttl 64
110/tcp   open  pop3    syn-ack ttl 64
111/tcp   open  rpcbind syn-ack ttl 64
143/tcp   open  imap    syn-ack ttl 64
MAC Address: 02:45:BF:8A:2D:6B (Unknown)

Read data files from: /usr/bin/./share/nmap
Nmap done: 1 IP address (1 host up) scanned in 1.59 seconds
Raw packets sent: 1002 (44.072KB) | Rcvd: 1002 (40.092KB)
```

you can use `-d` for debugging details or `-dd` for even more details. You can guarantee that using `-d` will create an output that extends beyond a single screen.